

PRACTICAL CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

ISO/IEC 27001:2022 & ISO/IEC 27002:2022

Practical ISMS, Risk, Audit, Controls, and Open-Source Tools

A working manual for managers, junior analysts, students, career changers, internal auditors, and security teams

Alberto (Al) Leiva

First Edition • July 2026

Inside: Clauses 4–10 • all 93 Annex A controls • risk • Statement of Applicability • audit • certification
• evidence • tools • labs • career preparation

Publication and Use Notice

Author: Alberto (Al) Leiva

Edition: First Edition, July 2026

This independent educational manual is not an ISO publication, legal advice, certification decision, audit report, or substitute for licensed ISO/IEC standards. ISO publications are copyrighted. The control and clause descriptions here are original summaries; use the official standards for exact requirements and guidance.

ISO develops standards but does not certify organizations. Certification is optional and is performed by certification bodies. Verify accreditation, scope, locations, version, and certificate status before relying on a certification claim.

Ethical and authorized use

Use technical tools only on systems, applications, networks, cloud accounts, repositories, and data that you own or are specifically authorized in writing to assess. Use synthetic data and isolated systems in laboratories.

Preface

A practical introduction to information-security management and evidence-based assurance.

ISO/IEC 27001 is a requirements standard for establishing, implementing, maintaining, and continually improving an information security management system. It uses risk management to preserve confidentiality, integrity, and availability in a way that fits the organization. ISO/IEC 27002 provides detailed control guidance but is not itself a certification standard.

The current base editions are ISO/IEC 27001:2022 and ISO/IEC 27002:2022. ISO/IEC 27001:2022 Amendment 1:2024 adds explicit climate-change consideration to organizational context and notes that interested parties may have climate-related requirements. The amendment does not mean that every organization must create a climate program; it must make and support a reasoned determination of relevance within the ISMS context.

A successful ISMS is not a folder of policies. It is a functioning management system: leaders set direction, risk owners make informed treatment decisions, teams operate controls, internal audit tests the system, management reviews results, and corrective action prevents recurrence.

How to Use This Manual

Managers should begin with Chapters 1–5 and 18–23.

Junior analysts should study clauses, Annex A themes, evidence testing, tools, lab, and interview preparation.

Internal auditors should focus on objective criteria, independence, complete populations, sampling, findings, corrective action, and follow-up.

Organizations seeking certification should confirm the licensed standard, amendment, certification scope, and accreditation expectations with competent professionals.

True Word contents: This document contains a native Word table-of-contents field and a verified chapter guide. After editing, right-click the contents and choose Update Field, then Update entire table.

Table of Contents

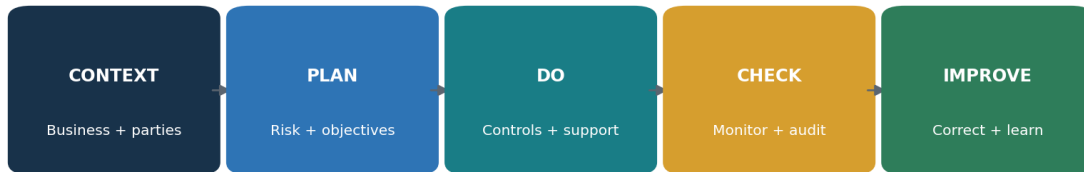
Publication and Use Notice	2
Ethical and authorized use	2
Preface	3
How to Use This Manual	4
Table of Contents	4
1. ISO/IEC 27001 and 27002 Foundations	7
2. ISMS Scope and Interested Parties	8
3. Risk Assessment and Risk Treatment	9
4. Statement of Applicability	10
5. Documentation and Evidence	11
6. Clause 4 — Context of the organization	12
7. Clause 5 — Leadership	13
8. Clause 6 — Planning	14
9. Clause 7 — Support	15
10. Clause 8 — Operation	16
11. Clause 9 — Performance evaluation	17
12. Clause 10 — Improvement	18
13. Annex A 5 Organizational controls	19
14. Annex A 6 People controls	22
15. Annex A 7 Physical controls	23

16. Annex A 8 Technological controls	24
17. Implementing Controls with ISO/IEC 27002	26
18. Metrics and Control Testing.....	27
19. Internal Audit.....	28
20. Management Review and Corrective Action	29
21. Certification Readiness.....	30
22. Open-Source Tools	31
22.1 CISO Assistant	31
22.2 SimpleRisk Community	31
22.3 Wazuh	31
22.4 osquery.....	32
22.5 OpenSCAP	32
22.6 Greenbone Community Edition	32
22.7 Nmap	32
22.8 Trivy.....	32
22.9 OWASP ZAP	33
22.10 Keycloak	33
22.11 DefectDojo.....	33
22.12 AIDE	33
22.13 Lynis	33
22.14 Open Policy Agent	33
23. Manager's ISMS Playbook	35
24. Junior Analyst Career Guide	36
24.1 Typical junior work.....	36
24.2 Skills employers value	37
25. Fictional Laboratory and Portfolio	38
26. Thirty-Day Learning Plan.....	39
27. Interview Preparation	40
27.1 What is an ISMS?	40
27.2 ISO 27001 versus 27002?.....	40
27.3 What is the SoA?	40
27.4 Are all Annex A controls mandatory?	40
27.5 How do you test a control?.....	40
27.6 What is a nonconformity?	40

27.7 What changed in 2024?	40
27.8 What can a junior analyst safely conclude?	40
27.9 Questions to ask the employer.....	40
28. Templates, Glossary, Index, and References	42
28.1 Minimal risk record	42
28.2 Control test workpaper	42
28.3 Glossary	42
28.4 Subject index	43
28.5 Official references.....	43

1. ISO/IEC 27001 and 27002 Foundations

Current editions, purpose, relationship, and important limitations.



An ISMS is a managed system of continual improvement—not a one-time control checklist

Figure 1. ISMS continual-improvement cycle

Document	Role	Certification
ISO/IEC 27001:2022	Normative ISMS requirements, including Annex A reference controls	Organizations can be certified to it
ISO/IEC 27001:2022/Amd 1:2024	Climate-action changes affecting context and interested-party consideration	Applied with the base standard
ISO/IEC 27002:2022	Implementation guidance for information-security controls	Not a certification standard
ISO/IEC 27005:2022	Guidance for information-security risk management	Supporting guidance, not the 27001 certification standard

- Clauses 4–10 contain requirements an organization must address for conformity.
- Annex A lists 93 reference controls in four themes: 37 organizational, 8 people, 14 physical, and 34 technological.
- Control selection follows risk treatment and applicable obligations; Annex A is not a universal checklist where every control must always be implemented.
- The Statement of Applicability records necessary controls, justification, implementation status, and justified exclusions from Annex A.

2. ISMS Scope and Interested Parties

How to define a defensible boundary for the management system.

- Identify business objectives, products, services, processes, information, legal entities, locations, people, suppliers, technologies, and dependencies.
- Understand relevant internal issues such as strategy, culture, skills, architecture, governance, and resources.
- Understand relevant external issues such as threats, laws, contracts, markets, suppliers, physical conditions, and technology change.
- Determine interested parties and relevant requirements, including customers, regulators, workers, owners, suppliers, communities, and certification stakeholders.
- Consider whether climate change is relevant to ISMS effectiveness and whether interested parties have climate-related requirements; document the reasoning.
- Define scope boundaries, interfaces, exclusions, dependencies, and justification in language that can be audited.
- Keep scope aligned with asset, process, network, cloud, supplier, and data-flow inventories.

Scope test	Manager question	Evidence
Boundary	Which legal entities, sites, services, processes, and technology are included?	Approved scope statement and maps
Interfaces	What connects the scope to other teams, systems, suppliers, and locations?	Data flows, architecture, contracts, responsibility matrix
Completeness	Could important information or risk be hidden outside the stated boundary?	Reconciled inventories and discovery
Change	What triggers a scope review?	Change records, acquisition and product gates
Climate relevance	Could climate effects or stakeholder expectations affect availability, suppliers, facilities, people, or obligations?	Context analysis, decision, actions when relevant

3. Risk Assessment and Risk Treatment

A repeatable method that connects business risk to control decisions.



Risk treatment links business context to justified controls and accepted residual risk

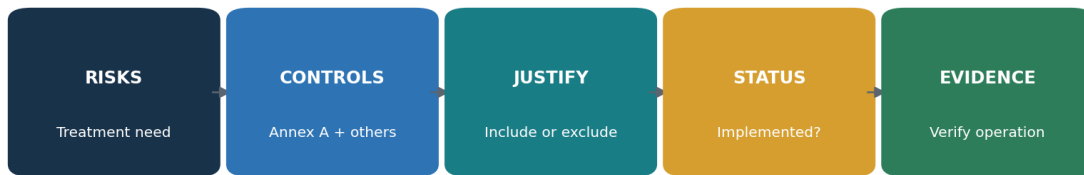
Figure 2. Information-security risk workflow

Define risk criteria before scoring: risk identification method, likelihood and consequence scales, calculation rules, acceptance thresholds, required treatment, escalation, review frequency, and risk-owner authority. Apply the method consistently enough to produce valid and comparable results.

Field	Example content
Asset or objective	Customer portal and contractually required availability
Threat event	Credential theft followed by unauthorized administrative access
Vulnerability or condition	Weak enrollment and no phishing-resistant MFA
Consequences	Data disclosure, outage, contractual breach, response cost
Existing controls	MFA, conditional access, logging, support verification
Inherent or current risk	Score using approved likelihood and consequence criteria
Treatment	Modify risk through stronger authentication and monitored recovery
Owner and date	Named accountable risk owner and target date
Residual risk	Reassess after treatment; obtain explicit owner approval

4. Statement of Applicability

The bridge between risk treatment, Annex A, other controls, and audit evidence.



The Statement of Applicability explains control decisions and implementation status

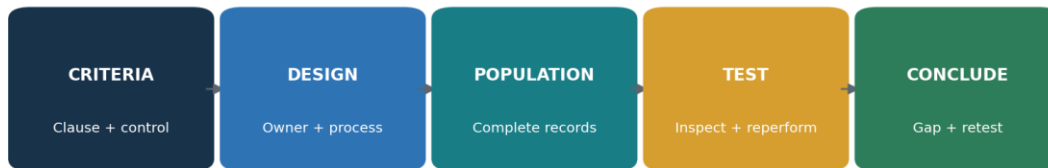
Figure 3. Statement of Applicability workflow

- List the controls necessary to treat identified information-security risks and meet legal, regulatory, contractual, and business requirements.
- Compare selected controls to Annex A so necessary reference controls are not overlooked.
- Record whether each Annex A control is applicable and justify inclusion or exclusion.
- Record implementation status clearly and keep it consistent with the risk-treatment plan and operating evidence.
- Include organization-specific controls when Annex A does not fully address a risk.
- Control the SoA as documented information and update it after material risk, scope, legal, supplier, technology, or control changes.

Control	Applicable?	Justification	Status	Owner / evidence
Example 8.15 logging	Yes	Needed for detection, investigation, and obligations	Implemented with open actions	Security Operations / source inventory and review records
Example 7.9 off-premises assets	Yes	Remote and traveling personnel use company devices	Implemented	IT Operations / inventory and encryption proof
Example organization control	Yes	Specific product-safety risk requires signed releases	Partially implemented	Engineering / pipeline records
Example exclusion	No	The described technology or scenario is absent from the controlled scope	Not applicable	Scope and architecture evidence

5. Documentation and Evidence

How to maintain useful documented information without creating bureaucracy.



Reliable conclusions connect criteria, scope, control design, evidence, testing, and correction

Figure 4. Requirement-to-evidence chain

Document or record	Purpose	Control checks
ISMS scope	Defines boundary and interfaces	Approved, current, consistent with reality
Policy	Sets direction and commitments	Approved, communicated, reviewed
Risk method and register	Shows repeatable assessment and decisions	Criteria applied consistently; owners approve residual risk
Risk-treatment plan	Tracks actions, owners, resources, and dates	Aligned to risks and SoA
Statement of Applicability	Explains control selection and status	All Annex A controls addressed; justifications supported
Objectives and metrics	Shows planned outcomes and evaluation	Measurable, owned, analyzed, acted upon
Competence and awareness records	Supports capability and understanding	Role-based, evaluated, current
Operational evidence	Shows controls actually operated	Complete, authentic, protected, retained
Audit and review records	Supports oversight and decisions	Objective, complete, followed through
Corrective-action records	Shows root cause and effective correction	Cause addressed, recurrence considered, effectiveness verified

6. Clause 4 — Context of the organization

Plain-language requirements, verification focus, and example evidence.

Clause purpose: Context of the organization

Clause	Plain meaning	Verification focus	Example evidence
4.1	Understand internal and external issues that can affect the ISMS; explicitly consider whether climate change is relevant.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
4.2	Identify relevant interested parties, their requirements, and whether they include climate-related expectations.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
4.3	Define and maintain the ISMS scope, including boundaries, interfaces, dependencies, locations, technology, and exclusions.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
4.4	Establish, operate, maintain, and continually improve the ISMS and its required processes.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.

Use the licensed official ISO/IEC 27001 text for exact normative requirements. This manual paraphrases concepts for education and does not replace the standard.

2024 amendment: Explicitly determine whether climate change is relevant to the ISMS context and recognize that relevant interested parties may have climate-related requirements. Keep evidence of the reasoning and any resulting action.

7. Clause 5 — Leadership

Plain-language requirements, verification focus, and example evidence.

Clause purpose: Leadership

Clause	Plain meaning	Verification focus	Example evidence
5.1	Top management demonstrates commitment, integrates the ISMS into business processes, supplies resources, and supports improvement.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
5.2	Establish, communicate, and maintain an information-security policy appropriate to the organization.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
5.3	Assign and communicate information-security responsibilities and reporting authority.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.

Use the licensed official ISO/IEC 27001 text for exact normative requirements. This manual paraphrases concepts for education and does not replace the standard.

8. Clause 6 — Planning

Plain-language requirements, verification focus, and example evidence.

Clause purpose: Planning

Clause	Plain meaning	Verification focus	Example evidence
6.1.1	Determine ISMS-level risks and opportunities, plan actions, integrate them into ISMS processes, and evaluate effectiveness.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
6.1.2	Define and apply consistent information-security risk criteria and assessment methods; identify owners and analyze and evaluate risks.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
6.1.3	Choose risk-treatment options and controls, compare them with Annex A, produce the Statement of Applicability and treatment plan, and obtain risk-owner approval.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
6.2	Set measurable security objectives with owners, resources, dates, and evaluation methods.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
6.3	Plan ISMS changes so their purpose, consequences, resources, responsibilities, and system integrity are considered.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.

Use the licensed official ISO/IEC 27001 text for exact normative requirements. This manual paraphrases concepts for education and does not replace the standard.

9. Clause 7 — Support

Plain-language requirements, verification focus, and example evidence.

Clause purpose: Support

Clause	Plain meaning	Verification focus	Example evidence
7.1	Provide people, funding, technology, and other resources needed by the ISMS.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
7.2	Define competence needs, close gaps, evaluate results, and keep evidence.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
7.3	Ensure people understand the policy, their contribution, and consequences of nonconformity.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
7.4	Plan what, when, with whom, and how the organization communicates internally and externally.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
7.5	Create, approve, identify, protect, distribute, retain, and control required documented information.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.

Use the licensed official ISO/IEC 27001 text for exact normative requirements. This manual paraphrases concepts for education and does not replace the standard.

10. Clause 8 — Operation

Plain-language requirements, verification focus, and example evidence.

Clause purpose: Operation

Clause	Plain meaning	Verification focus	Example evidence
8.1	Plan and control ISMS processes, criteria, changes, outsourced work, and evidence of proper operation.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
8.2	Perform information-security risk assessments at planned intervals and when significant changes occur.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
8.3	Implement the risk-treatment plan and retain evidence of results.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.

Use the licensed official ISO/IEC 27001 text for exact normative requirements. This manual paraphrases concepts for education and does not replace the standard.

11. Clause 9 — Performance evaluation

Plain-language requirements, verification focus, and example evidence.

Clause purpose: Performance evaluation

Clause	Plain meaning	Verification focus	Example evidence
9.1	Define what to monitor and measure, how and when to do it, who evaluates it, and how results are retained and analyzed.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
9.2.1	Conduct internal audits at planned intervals to evaluate conformity with organizational and ISO/IEC 27001 requirements and effective implementation.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
9.2.2	Maintain an audit program with frequency, methods, responsibilities, planning, reporting, scope, criteria, objective auditors, retained results, and timely corrective action.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
9.3.1	Top management reviews the ISMS at planned intervals for continuing suitability, adequacy, and effectiveness.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
9.3.2	Review required inputs such as previous actions, context changes, interested-party needs, performance, feedback, risk, treatment, and improvement opportunities.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
9.3.3	Record management-review decisions about improvement and needed ISMS changes.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.

Use the licensed official ISO/IEC 27001 text for exact normative requirements. This manual paraphrases concepts for education and does not replace the standard.



Internal audit must be objective, evidence-based, reported, and followed through correction

Figure 5. Internal-audit workflow

12. Clause 10 — Improvement

Plain-language requirements, verification focus, and example evidence.

Clause purpose: Improvement

Clause	Plain meaning	Verification focus	Example evidence
10.1	Continually improve the suitability, adequacy, and effectiveness of the ISMS.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.
10.2	React to nonconformities, correct them, analyze causes, prevent recurrence, verify effectiveness, and retain evidence.	Confirm ownership, scope, method, approval, operating evidence, exceptions, correction, and retained records.	Policies, registers, plans, records, minutes, results, approvals, and follow-up evidence.

Use the licensed official ISO/IEC 27001 text for exact normative requirements. This manual paraphrases concepts for education and does not replace the standard.



Annex A contains 93 reference controls; selection must follow risk treatment and applicability

Figure 6. Annex A control themes

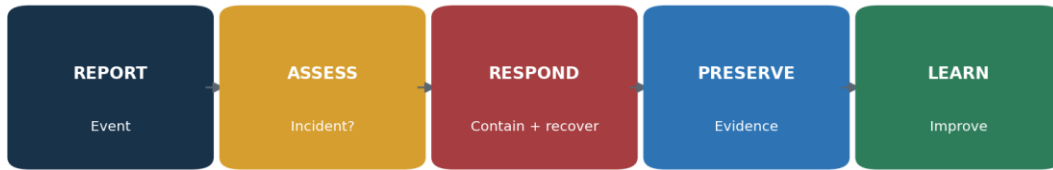
13. Annex A 5 Organizational controls

Original summaries of the reference controls, verification focus, and evidence examples.

Control	Practical meaning	Verification focus	Example evidence
5.1	Maintain approved information-security policies.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.2	Define security roles and responsibilities.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.3	Separate conflicting duties.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.4	Require managers to enforce security responsibilities.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.5	Maintain appropriate contact with authorities.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.6	Participate in relevant security groups and professional forums.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.7	Collect and use threat intelligence.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.8	Build security into project management.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.9	Inventory information and associated assets.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.10	Define acceptable use and handling rules.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.11	Recover organizational assets when roles end or change.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.12	Classify information according to need and risk.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.13	Label information consistently with classification.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.14	Protect information transfers.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.15	Establish access-control rules.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.16	Manage identities throughout their life cycle.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.17	Protect authentication information.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.18	Approve, review, modify, and remove access rights.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.19	Manage security risk in supplier relationships.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.20	Include security requirements in supplier agreements.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.21	Manage ICT supply-chain security risk.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.22	Monitor, review, and control supplier-service changes.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.23	Govern acquisition, use, management, and exit from cloud services.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.

Control	Practical meaning	Verification focus	Example evidence
5.24	Prepare and plan for security-incident management.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.25	Assess events and decide whether they are incidents.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.26	Respond to security incidents.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.27	Learn from incidents and improve controls.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.28	Identify, collect, acquire, and preserve evidence.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.29	Protect information during disruption.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.30	Prepare ICT to support business continuity.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.31	Identify and meet legal, regulatory, and contractual requirements.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.32	Protect intellectual-property rights.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.33	Protect records throughout their life cycle.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.34	Protect privacy and personally identifiable information.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.35	Arrange independent reviews of information security.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.36	Check compliance with security policies, rules, and standards.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
5.37	Maintain documented operating procedures.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.

Selection rule: Annex A is a reference set used to check that necessary controls were not overlooked. The organization may need other controls. Every inclusion or exclusion must be justified through risk treatment and recorded in the Statement of Applicability.



Incident management turns reported events into controlled response, evidence, and learning

Figure 7. Security-incident management

14. Annex A 6 People controls

Original summaries of the reference controls, verification focus, and evidence examples.

Control	Practical meaning	Verification focus	Example evidence
6.1	Screen candidates and personnel according to law, role, and risk.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
6.2	Include security responsibilities in employment terms.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
6.3	Provide continuing role-based awareness, education, and training.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
6.4	Operate a fair, communicated disciplinary process.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
6.5	Manage security duties after termination or role change.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
6.6	Use suitable confidentiality or non-disclosure agreements.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
6.7	Protect information during remote work.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
6.8	Make security-event reporting easy and timely.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.

Selection rule: Annex A is a reference set used to check that necessary controls were not overlooked. The organization may need other controls. Every inclusion or exclusion must be justified through risk treatment and recorded in the Statement of Applicability.

15. Annex A 7 Physical controls

Original summaries of the reference controls, verification focus, and evidence examples.

Control	Practical meaning	Verification focus	Example evidence
7.1	Define and protect physical security perimeters.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.2	Control physical entry.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.3	Secure offices, rooms, and facilities.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.4	Monitor premises for unauthorized physical access.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.5	Protect against physical and environmental threats.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.6	Apply working rules for secure areas.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.7	Use clear-desk and clear-screen practices.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.8	Site and protect equipment appropriately.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.9	Protect assets used away from organizational premises.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.10	Manage storage media throughout its life cycle.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.11	Protect supporting utilities.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.12	Protect power and data cabling.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.13	Maintain equipment securely.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
7.14	Securely dispose of or reuse equipment.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.

Selection rule: Annex A is a reference set used to check that necessary controls were not overlooked. The organization may need other controls. Every inclusion or exclusion must be justified through risk treatment and recorded in the Statement of Applicability.

16. Annex A 8 Technological controls

Original summaries of the reference controls, verification focus, and evidence examples.

Control	Practical meaning	Verification focus	Example evidence
8.1	Secure user endpoint devices.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.2	Control privileged access rights.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.3	Restrict access to information according to policy.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.4	Control access to source code and development tools.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.5	Use secure authentication.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.6	Manage capacity.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.7	Protect against malware.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.8	Manage technical vulnerabilities.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.9	Manage configurations.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.10	Delete information securely when no longer needed.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.11	Mask sensitive data when appropriate.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.12	Prevent data leakage.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.13	Maintain and test backups.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.14	Provide redundancy where availability requires it.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.15	Generate, protect, retain, and review logs.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.16	Monitor systems and networks for abnormal behavior.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.17	Synchronize clocks.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.18	Control powerful system utilities.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.19	Control software installation on operational systems.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.20	Secure networks.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.21	Secure network services.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.22	Segregate networks where needed.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.

Control	Practical meaning	Verification focus	Example evidence
8.23	Control access to external websites.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.24	Use and manage cryptography appropriately.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.25	Operate a secure development life cycle.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.26	Define application-security requirements.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.27	Apply secure architecture and engineering principles.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.28	Use secure coding practices.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.29	Perform security testing in development and acceptance.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.30	Control outsourced development.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.31	Separate development, test, and production environments.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.32	Manage changes securely.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.33	Protect test information.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.
8.34	Protect operational systems during audit testing.	Confirm risk or obligation, design, owner, implementation, operation, exceptions, and measurement.	Procedure, configuration, record, log, ticket, review, test, or observation.

Selection rule: Annex A is a reference set used to check that necessary controls were not overlooked. The organization may need other controls. Every inclusion or exclusion must be justified through risk treatment and recorded in the Statement of Applicability.

17. Implementing Controls with ISO/IEC 27002

How to turn risk decisions into controls that fit the organization.

1. Start with the risk-treatment decision, obligation, and expected outcome—not with a tool.
2. Use ISO/IEC 27002 guidance and relevant attributes to understand purpose, implementation considerations, and relationships.
3. Tailor the control to people, process, technology, physical environment, legal constraints, and business operations.
4. Define owner, scope, trigger, inputs, steps, outputs, records, frequency, dependencies, exceptions, and escalation.
5. Evaluate whether the design would reasonably achieve the intended outcome.
6. Implement through controlled change and train affected people.
7. Measure operation and effectiveness, investigate exceptions, and improve.
8. Update risks, treatment plan, SoA, procedures, and evidence when the control changes.

Important distinction: ISO/IEC 27002 provides guidance. The organization remains responsible for selecting and designing controls that treat its risks and meet applicable requirements.

18. Metrics and Control Testing

How to verify whether the ISMS and its controls work.

Area	Population and sample	Test	Evidence
Risk	All current risks; sample high, changed, accepted, and overdue items	Reperform scoring, trace treatment, confirm owner approval and review	Method, register, approvals, treatment and residual risk
Access	All workforce, privileged, service, and third-party identities	Test need, approval, MFA, review, change, inactivity, and termination	Populations, exports, tickets, settings and logs
Vulnerabilities	All assets and findings	Validate coverage, prioritization, exceptions, deadlines, correction, and rescan	Inventory, scans, tickets, approvals and retests
Suppliers	Complete supplier population; sample critical and changed services	Test due diligence, agreement, responsibility, monitoring, incident and exit	Inventory, assessment, contract, review and termination proof
Incidents	All reported events and incidents	Test classification, response, evidence, communications, recovery and learning	Cases, timeline, decisions, evidence log and lessons
Continuity	Critical processes and supporting ICT	Trace business needs to recovery design and exercises	BIA, plans, test records, gaps and retests
Objectives	All ISMS objectives and measures	Check definition, data quality, trend, target, analysis, decision, and action	Metric definitions, source data, dashboards, minutes and actions

- Define exact criteria, scope, period, population, control, owner, evidence, and expected outcome.
- Evaluate design before testing operation.
- Obtain the complete population and validate its completeness and accuracy independently.
- Select a risk-based sample covering relevant dates, owners, locations, failures, exceptions, and changes.
- Inspect records, observe work, interview personnel, examine configuration, and reperform where practical.
- Document exceptions as facts linked to criteria; do not exaggerate or hide limitations.
- Assign correction, root-cause analysis, owner, due date, interim protection, and escalation.
- Retest and state the final conclusion and remaining limitation.

19. Internal Audit

An independent evaluation of conformity and effective implementation.

Maintain an audit program that considers process importance, change, risk, and previous results.

Define objective, scope, criteria, timing, method, sampling, records, and reporting for each audit.

Select auditors who are competent and sufficiently objective; auditors should not audit their own work without safeguards.

Use the licensed standard, organizational requirements, risk decisions, SoA, policies, and applicable obligations as criteria.

Record evidence and findings clearly enough that another competent person can understand the basis.

Report results to relevant management and track corrections and corrective actions through effectiveness review.

Finding type	Meaning	Required response
Conformity	Evidence supports the criteria	Maintain and monitor
Opportunity for improvement	A useful improvement suggestion that is not a hidden nonconformity	Evaluate voluntarily and record decision
Nonconformity	One or more requirements are not fulfilled	Correct, analyze cause, act to prevent recurrence, and verify effectiveness
Audit limitation	Scope, evidence, time, independence, or access restricted the conclusion	Disclose clearly and resolve when possible

20. Management Review and Corrective Action

Leadership decisions that keep the ISMS suitable and effective.

Management-review input	Questions
Previous actions	Were prior decisions completed and effective?
Context and interested parties	What changed, including climate relevance and stakeholder needs?
Performance	What do metrics, objectives, incidents, audit results, and nonconformities show?
Interested-party feedback	What do customers, regulators, workers, suppliers, and owners report?
Risk and treatment	Are risk levels, acceptance, treatment, resources, and SoA still appropriate?
Improvement opportunities	What changes should leadership approve?

- Contain or correct the immediate problem.
- Determine the extent and whether similar failures exist elsewhere.
- Analyze root cause using evidence, not blame.
- Plan action proportionate to the effect and recurrence risk.
- Implement changes under ownership and due dates.
- Verify effectiveness using defined evidence after enough operating time.
- Update risk, controls, documents, training, objectives, and SoA when needed.

21. Certification Readiness

What certification does, how it generally proceeds, and what it does not guarantee.



Certification is optional and performed by certification bodies—not by ISO itself

Figure 8. Certification pathway

Certification is optional; organizations may implement ISO/IEC 27001 without seeking a certificate. ISO does not perform certification. An independent certification body conducts certification audits. Accreditation provides additional confidence in a certification body’s competence; verify the relevant accreditation and certificate scope.

Stage 1 generally evaluates readiness, scope, documented system, and preparation for the implementation audit.

Stage 2 evaluates implementation and effectiveness across the defined scope.

Surveillance and recertification activities evaluate continuing conformity; details should be confirmed with the selected certification body and accreditation rules.

A certificate is scoped and time-bound. It does not prove that every product is secure, that no incident can occur, or that every system in the company is included.

Readiness area	Acceptance check
Scope	Clear, supportable, reflected in real operations and certificate intent
Risk	Method used consistently; complete register; owners accept residual risk
SoA	All Annex A controls addressed; selections, exclusions, and status supported
Controls	Implemented, operated long enough to produce reliable evidence, and measured
Internal audit	Program and full-scope audit completed with objective evidence and follow-up
Management review	Required inputs considered and decisions recorded
Corrective action	Nonconformities corrected; cause and effectiveness addressed
Amendment	Climate relevance and interested-party requirements considered and evidenced

22. Open-Source Tools

Official links, safe quick starts, evidence, and limitations.

Tool	Purpose	Possible support
CISO Assistant	intuitem.github.io	ISMS, risks, controls, evidence
SimpleRisk Community	www.simplerisk.com	Risk register and treatment
Wazuh	wazuh.com	SIEM, endpoint monitoring, FIM
osquery	www.osquery.io	Endpoint inventory and queries
OpenSCAP	www.open-scap.org	Linux configuration assessment
Greenbone Community Edition	greenbone.github.io	Vulnerability management
Nmap	nmap.org	Asset and service discovery
Trivy	trivy.dev	Code, image, dependency, secret, and configuration scanning
OWASP ZAP	www.zaproxy.org	Authorized web-application testing
Keycloak	www.keycloak.org	Identity, MFA, roles, and logs
DefectDojo	www.defectdojo.org	Finding intake and remediation
AIDE	aide.github.io	File-integrity monitoring
Lynis	cisofy.com	Linux security auditing
Open Policy Agent	www.openpolicyagent.org	Policy as code

Critical limitation: Tools support controls and evidence; they do not select risk treatment, determine conformity, replace competent auditors, or certify an organization. Validate coverage, data quality, configuration, permissions, updates, and human review.

22.1 CISO Assistant

Purpose: ISMS, risks, controls, evidence. Official project: [CISO Assistant](https://github.com/intuitem)

Safe quick start: Deploy in an isolated test environment; create a framework project, scope, risk register, treatment actions, owners, and evidence records.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.2 SimpleRisk Community

Purpose: Risk register and treatment. Official project: [SimpleRisk Community](https://www.simplerisk.com)

Safe quick start: Install securely, define risk criteria, record risks and owners, choose treatments, track due dates, and export reviewed reports.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.3 Wazuh

Purpose: SIEM, endpoint monitoring, FIM. Official project: [Wazuh](https://wazuh.com)

Safe quick start: Install a lab manager and agent, confirm enrollment, trigger an authorized test event, review the alert, and preserve configuration and alert evidence.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.4 osquery

Purpose: Endpoint inventory and queries. Official project: [osquery](#)

Safe quick start: Install on a lab host, run read-only queries for software, users, processes, or settings, schedule approved queries, and document coverage.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.5 OpenSCAP

Purpose: Linux configuration assessment. Official project: [OpenSCAP](#)

Safe quick start: Select an appropriate profile, scan a lab system, validate findings manually, record exceptions, remediate, and rescan.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.6 Greenbone Community Edition

Purpose: Vulnerability management. Official project: [Greenbone Community Edition](#)

Safe quick start: Authorize targets, update feeds, run authenticated lab scans, validate coverage and findings, assign remediation, and rescan.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.7 Nmap

Purpose: Asset and service discovery. Official project: [Nmap](#)

Safe quick start: Use only on authorized ranges; begin with a limited service scan, compare results to inventory, investigate unknowns, and retain command and scope.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.8 Trivy

Purpose: Code, image, dependency, secret, and configuration scanning. Official project: [Trivy](#)

Safe quick start: Scan a test repository or container image, validate findings, suppress only with approval and reason, fix, and rescan.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.9 OWASP ZAP

Purpose: Authorized web-application testing. Official project: [OWASP ZAP](#)

Safe quick start: Proxy a training application, crawl passively, use active scanning only with written approval, validate results, and record remediation.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.10 Keycloak

Purpose: Identity, MFA, roles, and logs. Official project: [Keycloak](#)

Safe quick start: Create a lab realm, users, groups, least-privilege roles, MFA, session settings, and events; test joiner, mover, and leaver cases.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.11 DefectDojo

Purpose: Finding intake and remediation. Official project: [DefectDojo](#)

Safe quick start: Import safe scanner results, carefully deduplicate, assign owners, set risk-based deadlines, attach proof, and close only after retesting.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.12 AIDE

Purpose: File-integrity monitoring. Official project: [AIDE](#)

Safe quick start: Create a baseline on a lab host, make an authorized file change, run a check, investigate the difference, and protect the baseline.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.13 Lynis

Purpose: Linux security auditing. Official project: [Lynis](#)

Safe quick start: Audit a lab host, review suggestions against scope and risk, document decisions, remediate selected items, and rerun.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

22.14 Open Policy Agent

Purpose: Policy as code. Official project: [Open Policy Agent](#)

Safe quick start: Write a small lab rule, test allowed and denied inputs, version the policy and tests, and preserve results as supporting evidence.

Evidence: approved scope, configuration, version, coverage, results, review, exception, remediation, and retest. Protect credentials, logs, reports, and backups.

23. Manager's ISMS Playbook

Questions, dashboard, ownership, and decisions managers must control.

Is the ISMS scope still aligned with strategy, services, locations, suppliers, cloud use, people, and data flows?

What changed in context, interested parties, legal obligations, threats, technology, or climate relevance?

Are the risk criteria reliable, and are owners explicitly approving the treatment and residual risk?

Does the SoA match real control implementation and open actions?

Are objectives and metrics producing decisions rather than decorative dashboards?

Are incidents, audit findings, exceptions, overdue actions, and repeat failures escalated?

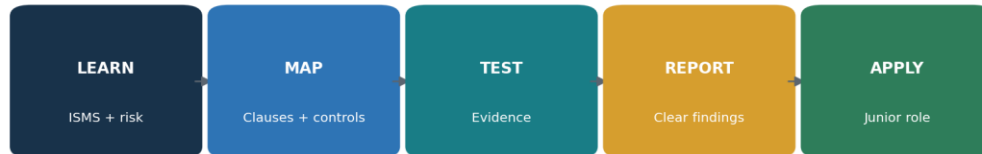
Do internal audit and management review have enough independence, competence, time, and evidence?

Are certification claims, scope, accreditation, and customer statements accurate?

Area	Manager question	Status
Context and scope	Are boundaries, dependencies, parties, and changes current?	Green / Yellow / Red
Risk	Are the criteria consistent and the owner's decisions timely?	Green / Yellow / Red
SoA and controls	Are selection, status, and evidence aligned?	Green / Yellow / Red
Performance	Do objectives, metrics, incidents, and trends drive action?	Green / Yellow / Red
Suppliers	Are risk, responsibility, monitoring, incidents, and exits controlled?	Green / Yellow / Red
Assurance	Are audits objective and findings corrected effectively?	Green / Yellow / Red
Improvement	Are root causes, recurrence, and lessons addressed?	Green / Yellow / Red
Certification	Are claims scoped, current, and supportable?	Green / Yellow / Red

24. Junior Analyst Career Guide

A practical route into ISMS, GRC, risk, audit, and compliance work.



A strong junior portfolio uses synthetic data, safe tools, traceable evidence, and honest conclusions

Figure 9. Junior ISO 27001 analyst pathway

Junior GRC Analyst
 ISO 27001 Compliance Analyst
 Security Controls Analyst
 ISMS Coordinator
 Risk Analyst
 Internal Audit Associate
 Third-Party Risk Analyst
 Security Assurance Analyst

24.1 Typical junior work

- Maintain scope, asset, obligation, supplier, risk, control, SoA, evidence, finding, and action registers.
- Gather evidence without changing source records and validate completeness.
- Map risks and requirements to controls, owners, procedures, systems, and evidence.
- Test samples for access, change, vulnerability, incident, backup, supplier, awareness, physical, and continuity controls.
- Support internal audits, management reviews, metrics, corrective actions, and certification preparation.
- Write factual conclusions and disclose sampling, scope, and evidence limitations.
- Protect confidential information and stay within authorization.

24.2 Skills employers value

Skill	Proof
ISMS concepts	Explain clauses 4–10 and continual improvement
Risk	Build a consistent register and treatment plan
SoA	Justify selections, exclusions, status, and evidence
Evidence testing	Define populations, samples, procedures, exceptions, and retests
Technical literacy	Interpret identity, cloud, logging, vulnerability, backup, and configuration evidence
Communication	Write concise findings, actions, and management summaries
Ethics	Use synthetic data, authorized systems, and honest claims

25. Fictional Laboratory and Portfolio

A safe practice environment using synthetic data and authorized lab systems.

Lab rule: Use a fictional organization, synthetic data, isolated systems, and tools you are authorized to operate. Do not claim that a portfolio project is a real certification or client audit.

1. Create a fictional company with two products, one cloud service, a remote workforce, and three suppliers.
2. Write a one-page context analysis, interested-party register, climate-relevance determination, and scope statement.
3. Create risk criteria and a ten-scenario risk register with owners and treatment decisions.
4. Create a treatment plan and SoA that addresses all 93 Annex A controls with concise justifications and honest implementation status.
5. Build sample policies, procedures, objectives, metrics, asset and supplier registers, training record, incident record, and continuity exercise.
6. Use a few open-source tools in isolated labs and capture scope, configuration, results, validation, remediation, and retest evidence.
7. Design and execute an internal-audit plan against selected clauses and controls.
8. Write two nonconformities, root-cause records, corrective actions, and effectiveness tests.
9. Create management-review minutes showing inputs, decisions, owners, resources, and deadlines.
10. Publish only sanitized, synthetic artifacts with a clear limitations statement.

Portfolio artifact	What it demonstrates
Context, parties, scope	Clause 4 reasoning and boundaries
Risk method, register, treatment	Clause 6 and risk ownership
Statement of Applicability	Traceable control decisions
Control test workpaper	Evidence, sampling, exception, and conclusion
Internal-audit package	Program, plan, criteria, report, and follow-up
Management-review minutes	Leadership evaluation and decisions
Corrective-action record	Root cause and effectiveness
Tool evidence memo	Technical literacy and limitations

26. Thirty-Day Learning Plan

A focused schedule for building useful junior-level capability.

Days	Focus	Deliverable
1–5	ISMS, CIA, clauses, ISO 27001/27002 relationship, scope	One-page concept map and scope statement
6–10	Risk criteria, scenarios, assessment, treatment, acceptance	Ten-risk register and treatment plan
11–14	Annex A themes and Statement of Applicability	Complete fictional SoA
15–18	Policies, competence, communication, document control, operations	Evidence index and three sample procedures
19–22	Metrics, monitoring, internal audit, management review	Metric sheet, audit plan, review agenda
23–25	Nonconformity, root cause, corrective action, improvement	Two finding and corrective-action records
26–28	Authorized open-source tool labs	Two evidence and retest memos
29–30	Portfolio cleanup and interview practice	Sanitized portfolio and five STAR stories

27. Interview Preparation

Clear answers, practical scenarios, and questions for the employer.

27.1 What is an ISMS?

A management system for controlling information-security risk through leadership, planning, operation, evaluation, and continual improvement.

27.2 ISO 27001 versus 27002?

27001 contains certifiable ISMS requirements; 27002 provides detailed control guidance and is not itself a certification standard.

27.3 What is the SoA?

A controlled record of necessary controls, Annex A inclusion or exclusion justification, and implementation status, linked to treatment and evidence.

27.4 Are all Annex A controls mandatory?

The organization must use Annex A as a reference check and justify decisions. Necessary controls follow risk treatment and obligations; other controls may also be required.

27.5 How do you test a control?

Define criteria and scope, validate the population, sample by risk, inspect and reperform evidence, document exceptions, and retest correction.

27.6 What is a nonconformity?

Failure to fulfill a requirement. It requires correction, cause evaluation, appropriate action, and effectiveness review.

27.7 What changed in 2024?

The amendment requires explicit climate-change relevance consideration in context and notes that interested parties may have climate-related requirements.

27.8 What can a junior analyst safely conclude?

State facts supported by defined evidence and scope, disclose limitations, and avoid claiming auditor or certification authority.

27.9 Questions to ask the employer

- What is the certified or intended ISMS scope?
- Who owns risk acceptance and the SoA?

- How are evidence populations produced and validated?
- What systems manage risks, controls, suppliers, findings, and corrective action?
- How is internal-auditor independence maintained?
- Which technical teams will this role work with?
- How are junior conclusions reviewed and coached?

28. Templates, Glossary, Index, and References

Reusable work structures, important terms, and authoritative starting points.

28.1 Minimal risk record

Field	Entry
Risk ID and owner	_____
Objective / asset	_____
Threat event and condition	_____
Consequence	_____
Existing controls	_____
Likelihood and impact	_____
Current risk	_____
Treatment and action owner	_____
Residual risk and acceptance	_____
Review date	_____

28.2 Control test workpaper

Field	Entry
Criteria and control	_____
Scope and period	_____
Owner and systems	_____
Population and completeness check	_____
Sample and rationale	_____
Procedure performed	_____
Evidence inspected	_____
Exceptions	_____
Conclusion and limitation	_____
Correction and retest	_____

28.3 Glossary

Term	Meaning
Annex A	Reference set of 93 information-security controls in ISO/IEC 27001:2022.
CIA	Confidentiality, integrity, and availability.
Conformity	Fulfillment of a requirement.
Control	Measure that modifies or maintains risk.
Corrective action	Action addressing the cause of a nonconformity to prevent recurrence.
Documented information	Information the organization must control and maintain or retain.
Interested party	Person or organization that can affect, be affected by, or perceive itself affected by a decision or activity.
ISMS	Information security management system.
Nonconformity	Failure to fulfill a requirement.
Residual risk	Risk remaining after treatment.
Risk owner	Person or entity accountable and authorized to manage a risk.
SoA	Statement of Applicability.
Top management	Person or group directing and controlling the organization at the highest level within scope.

28.4 Subject index

Subject	Chapter
Annex A controls	13–16
Audit	19
Certification	21
Climate amendment	1, 2, 6, 21
Corrective action	12, 20
Evidence	5, 18
Interested parties	2, 6
Junior analyst	24–27
Management review	11, 20
Metrics	11, 18
Open-source tools	22
Risk assessment and treatment	3, 8, 10
Scope	2, 6
Statement of Applicability	4
Suppliers	13, 18, 23

28.5 Official references

[ISO/IEC 27001:2022 overview](#)

[ISO/IEC 27001:2022/Amd 1:2024](#)

[ISO/IEC 27002:2022 overview](#)

[ISO/IAF climate-change communiqué](#)

[ISO certification overview](#)

[ISO/IEC 27000 family](#)

Final reminder: Purchase or lawfully access the official standards before implementation or assessment. Confirm current editions, amendments, accreditation, certification scope, legal requirements, contracts, technology, threats, and organizational change.